

PING

Koło Naukowe
Politechniki Gdańskiej



Packet Squirrel MK1

Fizyczny atak Man-in-the-Middle

Karol Kwiatek

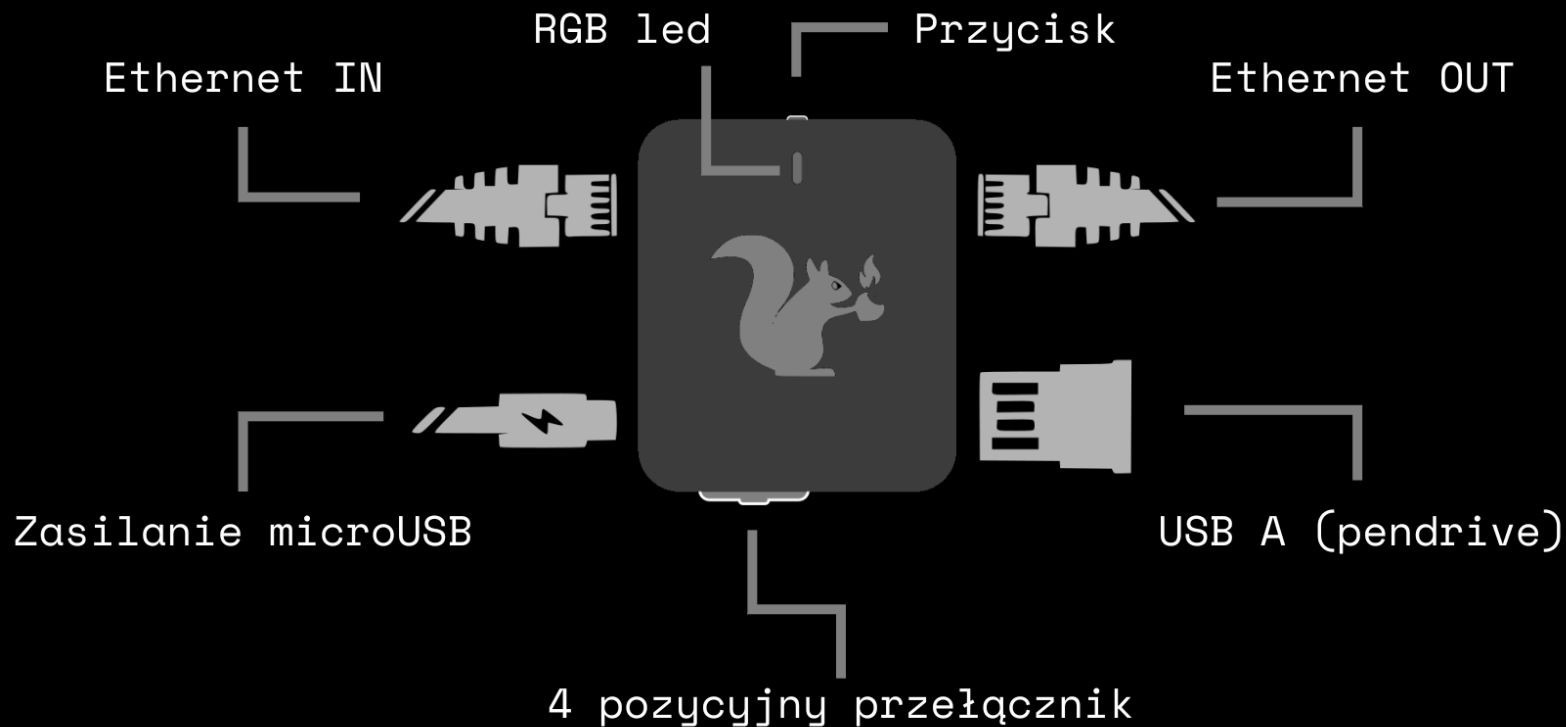


Czym jest Packet Squirrel?

- Miniaturowe urządzenie MITM od Hak5
- Wpina się fizycznie między ofiarę a sieć
- Cały ruch Ethernet przepływa przez urządzenie
- Wielkość ok. 5 x 4 x 2 cm
- Zasilanie z powerbanku lub portu usb



Budowa urządzenia



Specyfikacja techniczna

- CPU – Atheros AR9331, 400MHz
- RAM / FLASH – 64MB / 16MB
- System – OpenWrt (Linux)
- Porty – 2x Ethernet 10/100, USB-A, microUSB
- Dostęp – Tylko przez SSH (brak Web UI)



Tryby pracy (NETMODE)

Tryb	Opis	Widoczny?
TRANSPARENT	Most L2, brak IP	Nie
BRIDGE	Most L2, PS ma IP	Tak
NAT	PS = router dla ofiary	Tak
VPN	NAT + tunel OpenVPN	Tak
CLONE	Klonuje MAC ofiary	Jako ofiara

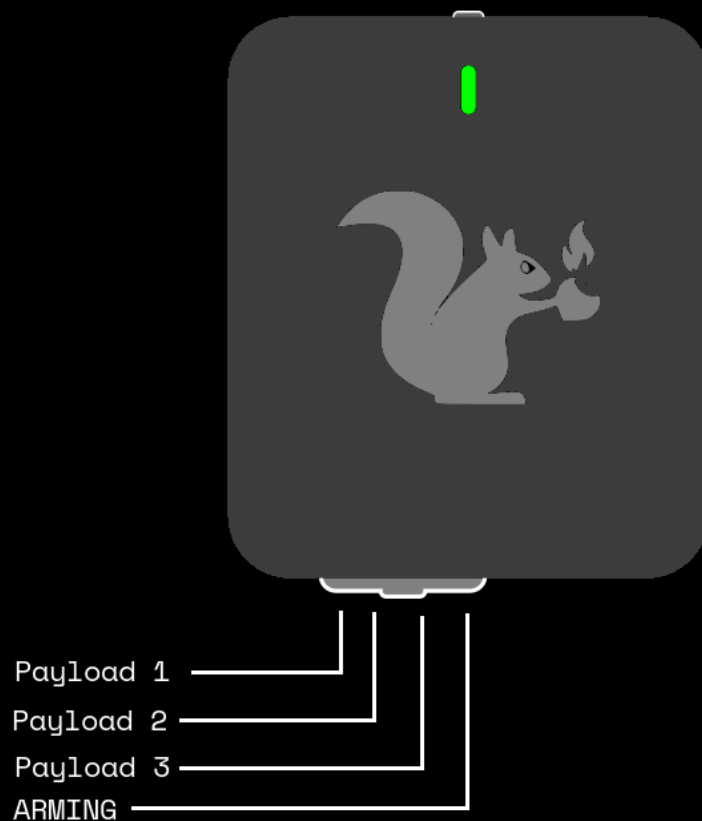
TRANSPARENT



NAT

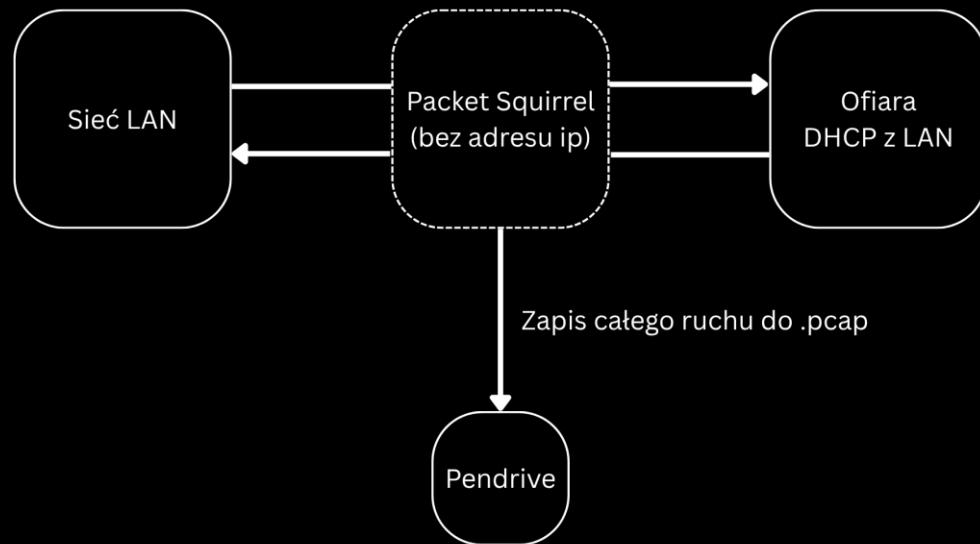


Uruchamianie ataków



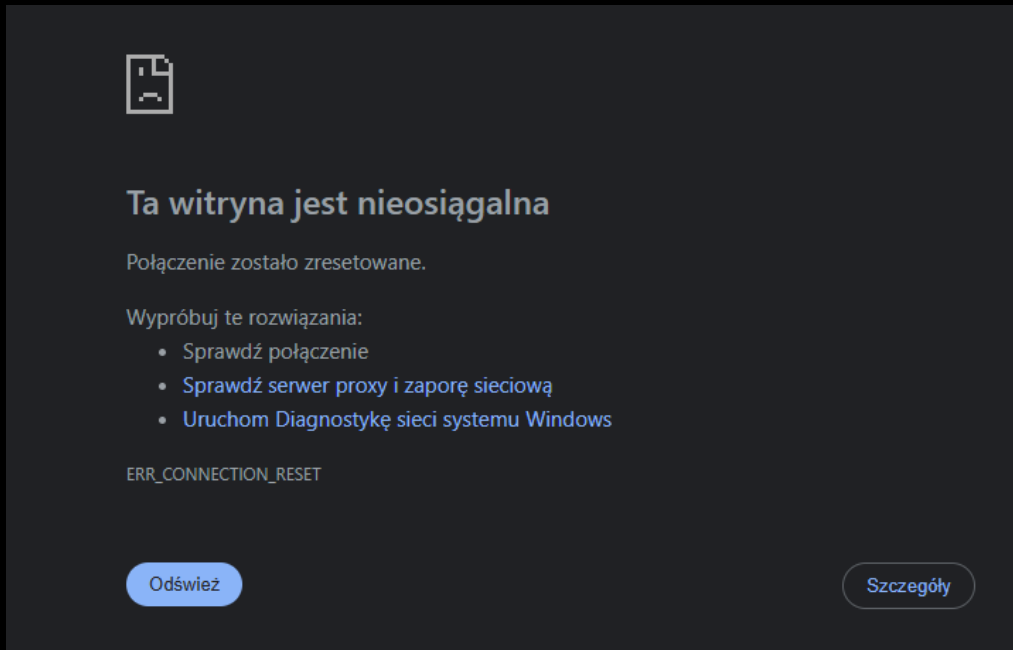
Atak 1: Przechwytywanie ruchu

- Tryb TRANSPARENT
- Tpcdump - cały ruch na pendrive
- Analiza offline w Wireshark



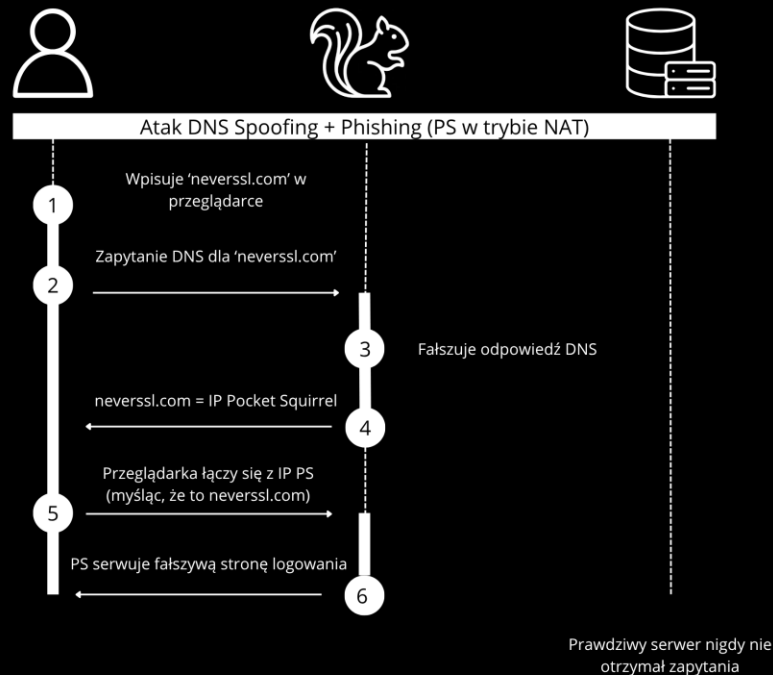
Atak 2: Selektywne blokowanie usług (DoS)

- PS odrzuca pakiety TCP przez REJECT
- Ofiara widzi „Connection Reset” – strona się nie ładuje
- Można blokować po porcie (80, 443) lub po treści (string match)



Atak 3: DNS Spoofing + Phishing

- Tryb NAT
- Iptables REDIRECT + dnsmasq
- Efekt: Ofiara widzi fałszywą stronę pod prawdziwym URL



Atak 3: DNS Spoofing + Phishing

- Ofiara wchodzi na stronę po HTTP
- PS serwuje ofierze fałszywą stronę
- Po wprowadzeniu danych logowania ofiara jest przekierowywana na prawdziwą stronę, a PS przesyła wykradzione dane atakującemu



Packet Squirrel **APL**



Packet Squirrel uruchomiony!

Tryb: DNS Spoofing + Phishing server

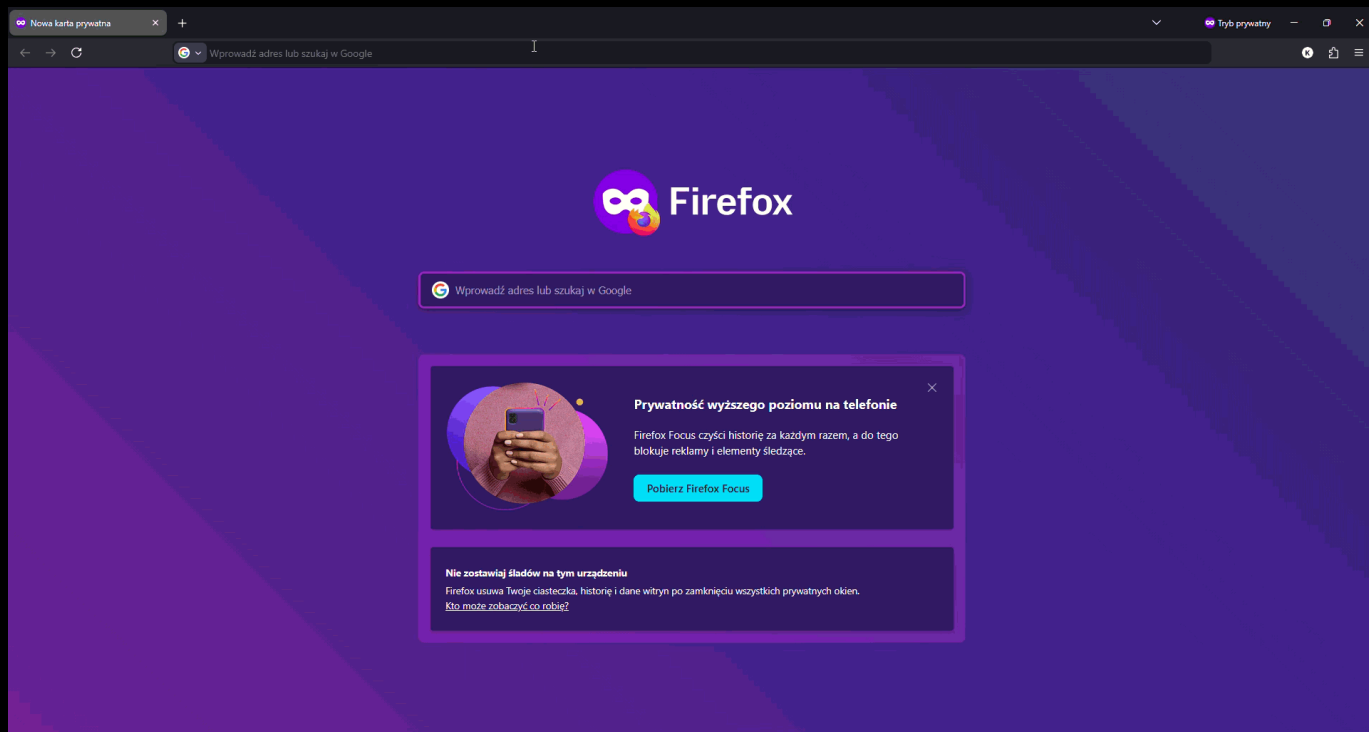


Packet Squirrel **APL**

2026-01-01 22:56:56 | testowyLogin | testoweHaslo



Atak 3: DNS Spoofing + Phishing



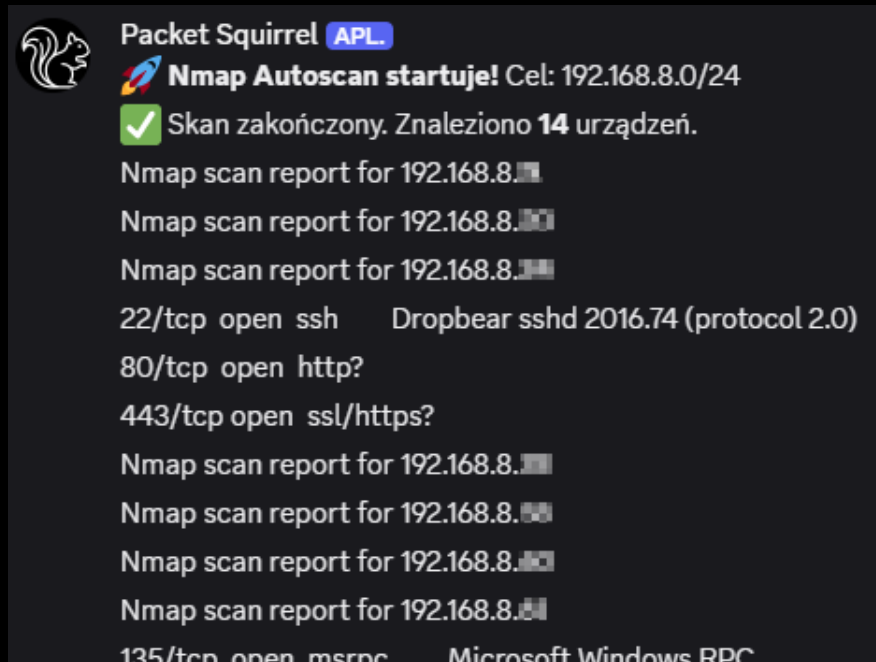
DNS Spoofing – kiedy nie działa?

- HSTS preload: facebook.com, google.com, github.com
- Strony z HTTPS + ważny certyfikat – ofiara zobaczy ostrzeżenie
- DoH (DNS over HTTPS) – zapytania DNS są szyfrowane



Atak 4: NMAP autoscan

- PS po wpięciu automatycznie skanuje sieć Nmapem
- Wyniki wysyłane są przez webhook (Discord, Telegram..)
- Działa bez nadzoru – atakujący nie potrzebuje SSH ani dostępu do sieci.



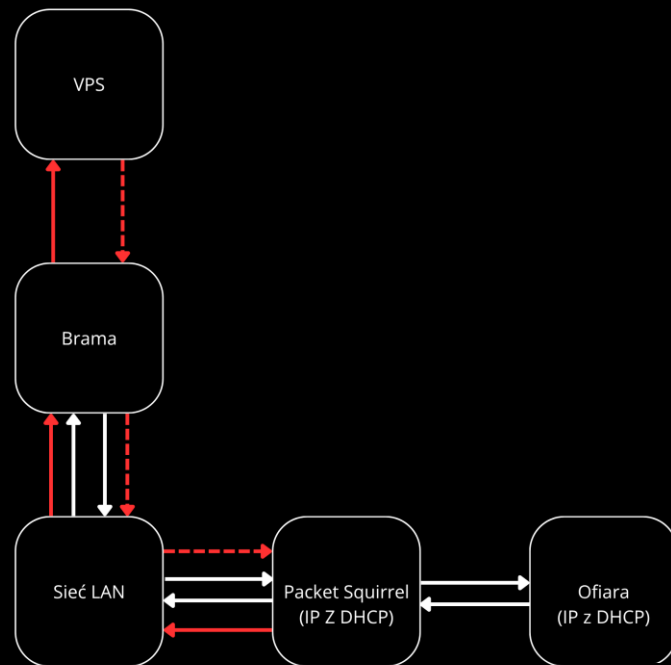
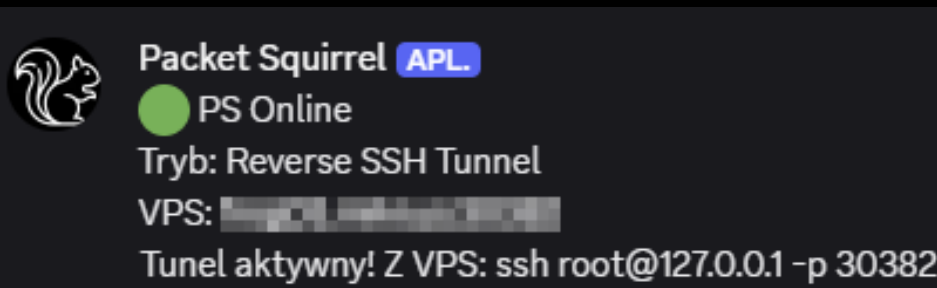
Atak 5: Zdalny implant sieciowy (OpenVPN*)

- PS inicjuje połączenie na zewnątrz
- Atakujący uzyskuje dostęp do sieci ofiary
- PS może pracować miesiącami niezauważony



Atak 5: Zdalny implant sieciowy (SSH tunnel)

- Lekka alternatywa dla OpenVPN – mniej obciążający CPU
- Auto-reconnect przez pętle w payloadzie
- Powiadomienia przez webhooki o stanie tunelu



Atak 5: Zdalny implant sieciowy (SSH tunnel)

```
Command Prompt
Command Prompt - ssh frogi

C:\Users\LENOVO>ssh [redacted]
[redacted] password:
[redacted]:~$ ssh root@127.0.0.1 -p 30382
Warning: Permanently added '[127.0.0.1]:30382' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html

BusyBox v1.23.2 (2018-09-27 06:21:55 UTC) built-in shell (ash)

  _  (\\_      Packet Squirrel      _//) _
  (_ \ ( '.)      by Hak5          (.' )/ _
   ) \ _))      _                  (( _ / (
  (_ )_      (') Nuts for Networks ((') _(_ _)
```

root@squirrel:~# |



Co jeszcze potrafi?

- ARP Spoofing – podszywanie się pod bramę L2
- SSL Stripping – „zdejmowanie” HTTPS, ofiara widzi HTTP
- Session Hijacking – kradzież ciasteczek sesji
- Content Injection – Modyfikowanie wyświetlanych stron
- Credential Harvesting – automatyczne wyciąganie haseł z ruchu

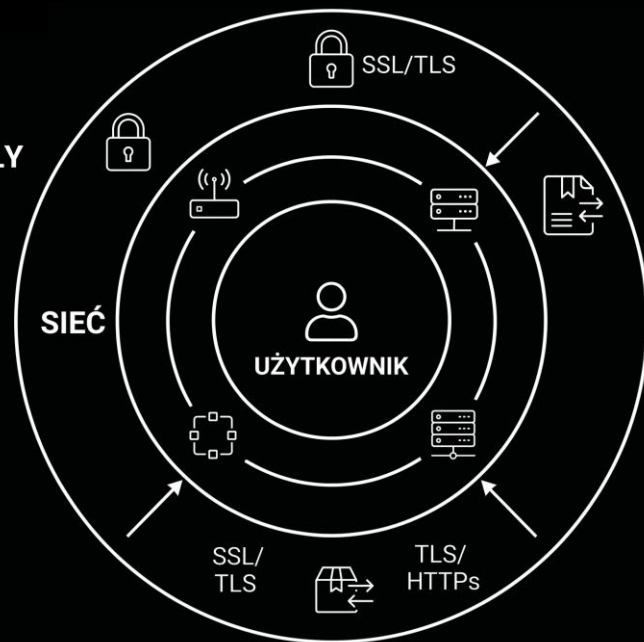
*„Packets go in. Packets go out.
What happens in between is up to
you.”*



Jak się bronić?

Poziom	Mechanizm	Chroni przed
Użytkownik	HTTPS, VPN, DoH	Sniffing, DNS Spoofing
Sieć	802.1X, Port Security, DAI	Fizyczne wpięcie, ARP spoofing
Protokoły	HSTS, DNSSEC, TLS 1.3	SSL Stripping, DNS Spoofing

PROTOKOŁY



Podsumowanie

- Packet Squirrel MK1 = fizyczny MITM za ~150 dolarów
- Wymaga dostępu do kabla Ethernet – bezpieczeństwo fizyczne jest kluczowe
- Ataki działają głównie na niezaszyfrowanym ruchu (HTTP, DNS, FTP)
- HTTPS + DOH + VPN = skuteczna obrona
- 802.1X na switchach = obrona przed fizycznym wpięciem

